

Universidad Nacional Autónoma de México



Facultad de Ingeniería

Alumno:

Lara Hernandez Angel Husiel - 320060829

Lugo Manzano Rodrigo - 320206968

Flores Colin Victor Jaziel - 320266083

Garcia Cortes Adolfo de Jesus - 320317264

Seguridad informatica basica

Semestre: 2027-1

Actividad 8

Mapeo de Categorías y Subcategorías de The NIST Cybersecurity Framework (CSF) 2.0 con las Actividades del Semestre

Fecha de Entrega:

14 de Noviembre del 2026

Índice

1 Categorías y Subcategorías por Función Core de The NIST CSF 2.0 . . . . . **1**

2 Mapeo de Categorías, Subcategorías y Actividades Realizadas en el Semestre **1**

2.1 Función 1: GOVERN (GV) — Gobernanza 1

2.2 Función 2: IDENTIFY (ID) — Identificar 3

2.3 Función 3: PROTECT (PR) — Proteger 4

2.4 Función 4: DETECT (DE) — Detectar 6

2.5 Función 5: RESPOND (RS) — Responder 7

2.6 Función 6: RECOVER (RC) — Recuperar 7

3 Total de Categorías y Subcategorías Cubiertas en el Curso **8**

1. Categorías y Subcategorías por Función Core de The NIST CSF 2.0

El núcleo (*Core*) de **The NIST Cybersecurity Framework (CSF) 2.0** (National Institute of Standards and Technology, 2024) organiza la gestión de riesgos de ciberseguridad en **6 Funciones Core**, las cuales se dividen en **22 Categorías** y **106 Subcategorías**. En la Tabla 1 se presentan las categorías y subcategorías consideradas para cada función del framework.

Tabla 1: Funciones Core, Categorías y Subcategorías consideradas en The NIST CSF 2.0.

Función Core	Categorías Consideradas (22)	Subcategorías Consideradas (106)
1. GOVERN (GV) (Gobernanza)	**GV.OC**: Contexto Organizacional **GV.RM**: Estrategia de Gestión de Riesgos **GV.RR**: Roles, Responsabilidades y Autoridades **GV.PO**: Políticas **GV.OV**: Supervisión (*Oversight*) **GV.SC**: Gestión de Riesgos en Cadena de Suministro	GV.OC-01 a GV.OC-05 (5 subcategorías) GV.RM-01 a GV.RM-07 (7 subcategorías) GV.RR-01 a GV.RR-04 (4 subcategorías) GV.PO-01 a GV.PO-02 (2 subcategorías) GV.OV-01 a GV.OV-03 (3 subcategorías) GV.SC-01 a GV.SC-10 (10 subcategorías)
2. IDENTIFY (ID) (Identificar)	**ID.AM**: Gestión de Activos (*Asset Management*) **ID.RA**: Evaluación de Riesgos (*Risk Assessment*) **ID.IM**: Mejora (*Improvement*)	ID.AM-01 a ID.AM-08 (7 subcategorías) ID.RA-01 a ID.RA-10 (10 subcategorías) ID.IM-01 a ID.IM-04 (4 subcategorías)
3. PROTECT (PR) (Proteger)	**PR.AA**: Gestión de Identidad, Autenticación y Acceso **PR.AT**: Concientización y Capacitación **PR.DS**: Seguridad de los Datos (*Data Security*) **PR.PS**: Seguridad de Plataformas **PR.IR**: Resiliencia de la Infraestructura Tecnológica	PR.AA-01 a PR.AA-06 (6 subcategorías) PR.AT-01 a PR.AT-02 (2 subcategorías) PR.DS-01, 02, 10, 11 (4 subcategorías) PR.PS-01 a PR.PS-06 (6 subcategorías) PR.IR-01 a PR.IR-04 (4 subcategorías)
4. DETECT (DE) (Detectar)	**DE.CM**: Monitoreo Continuo **DE.AE**: Análisis de Eventos Adversos	DE.CM-01, 02, 03, 06, 09 (5 subcategorías) DE.AE-02 a DE.AE-08 (6 subcategorías)
5. RESPOND (RS) (Responder)	**RS.MA**: Gestión de Incidentes **RS.AN**: Análisis de Incidentes **RS.CO**: Reporte y Comunicación de Respuesta **RS.MI**: Mitigación de Incidentes	RS.MA-01 a RS.MA-05 (5 subcategorías) RS.AN-03, 06, 07, 08 (4 subcategorías) RS.CO-02 a RS.CO-03 (2 subcategorías) RS.MI-01 a RS.MI-02 (2 subcategorías)
6. RECOVER (RC) (Recuperar)	**RC.RP**: Ejecución del Plan de Recuperación **RC.CO**: Comunicación de Recuperación	RC.RP-01 a RC.RP-06 (6 subcategorías) RC.CO-03 a RC.CO-04 (2 subcategorías)

2. Mapeo de Categorías, Subcategorías y Actividades Realizadas en el Semestre

A continuación se presenta la identificación y el mapeo de las categorías y subcategorías del **NIST CSF 2.0** que se relacionan con los temas explicados en clase, las **Actividades 1 a 7**, las **Prácticas 1 a 7**, la **Presentación en clase** y las **Tareas 1 a 3** desarrolladas durante el semestre. Las filas que pertenecen a una misma categoría se encuentran unificadas bajo una sola celda en la primera columna.

2.1. Función 1: GOVERN (GV) — Gobernanza

Tabla 2: Mapeo de Categorías y Subcategorías de la función **GOVERN (GV)** con las actividades del semestre.

Categoría	**Subcategoría Relacionada**	**Actividad / Práctica / Tarea**	**Qué se hizo en el semestre y cómo se relaciona**
GV.OC Contexto Organizacional	`GV.OC-01`: La misión organizacional se comprende e informa la gestión de riesgos.	**Clase y Actividad 2**	Se analizó el giro de negocio, misión, visión y objetivos estratégicos de una organización para comprender qué procesos operativos deben protegerse prioritariamente.
	`GV.OC-02`: Las partes interesadas internas y externas y sus expectativas de ciberseguridad se comprenden.	**Actividad 2, Actividad 6, Actividad 7 y Tarea 2**	Se identificaron las áreas internas (ingeniería, operaciones, TI, finanzas) y externas (clientes, socios comerciales, reguladores), así como las expectativas éticas de la sociedad en la **Tarea 2**.
	`GV.OC-03`: Los requisitos legales, regulatorios y contractuales (incluyendo privacidad) se comprenden y gestionan.	**Clase, Actividad 1, Actividad 6 y Actividad 7**	En clase y en la **Actividad 1** se revisaron normativas como ISO/IEC 27001, y en las **Actividades 6 y 7** se evaluó el cumplimiento de leyes de protección de datos personales (LFPDPPP), estándares de industria (ISO/SAE 21434, TISAX) y acuerdos de confidencialidad (NDA).
	`GV.OC-04`: Los objetivos, capacidades y servicios críticos de los que dependen terceros se comprenden.	**Actividad 2, Actividad 3 y Actividad 6**	Se determinaron cuáles son los servicios y operaciones críticas de la organización y cuál sería el impacto operativo y financiero si llegaran a detenerse.
	`GV.OC-05`: Los resultados, capacidades y servicios de los que depende la organización se comprenden y comunican.	**Práctica 2, Actividad 2, Actividad 3 y Actividad 6**	En la **Práctica 2**, mediante consultas DNS y `whois`, se identificó que dominios institucionales dependen de infraestructura externa alojada en Amazon Web Services (AWS) y Cloudflare. En las **Actividades 2 y 3** se mapearon las dependencias en nube y proveedores externos.
GV.RM Estrategia de Gestión de Riesgos	`GV.RM-01`: Los objetivos de gestión de riesgos se establecen y acuerdan. `GV.RM-02`: Las declaraciones de apetito y tolerancia al riesgo se establecen y mantienen.	**Clase, Actividad 6, Actividad 7 y Tarea 3**	En la **Actividad 7** se definieron metas medibles de reducción de riesgo (cumplimiento del 70 % de hitos) y umbrales de tolerancia en indicadores KRI. En la **Tarea 3** (conferencia *The Defensible Minimum*) se estudió la aceptación consciente del riesgo residual.
	`GV.RM-03`: La gestión de riesgos de ciberseguridad se incluye en los procesos de riesgo empresarial (ERM).	**Clase, Actividad 6 y Actividad 7**	En la **Actividad 7** se integró el riesgo cibernético dentro de las categorías empresariales (Estratégico, Operativo, Financiero, Cumplimiento y Tecnológico) evaluando pérdidas económicas, costos de respuesta, reputación y multas.
	`GV.RM-04`: Se establece dirección estratégica que describe opciones de respuesta al riesgo. `GV.RM-05`: Se establecen líneas de comunicación para riesgos.	**Clase, Actividad 6 y Actividad 7**	Se trabajaron en clase y en las **Actividades 6 y 7** las cuatro estrategias de respuesta al riesgo (**Mitigar, Transferir, Evitar y Aceptar**), justificando cuál aplicar en cada escenario y definiendo el reporte hacia el Comité de Riesgos y dirección.
	`GV.RM-06`: Se establece un método estandarizado para calcular, documentar, categorizar y priorizar los riesgos.	**Clase, Actividad 4, Actividad 6 y Actividad 7**	En la **Actividad 4** se utilizó el estándar **CVSS v3.1**; en la **Actividad 6** se construyó la plantilla del **Registro de Riesgos** (redactando riesgos en Forma 1 y Forma 2); y en la **Actividad 7** se aplicó el cálculo cuantitativo de Frecuencia (F), Impacto promedio (I) y Nivel de Riesgo ($R = F \times I$).
GV.RR Roles, Responsabilidades y Autoridades	`GV.RR-01`: Liderazgo responsable y cultura ética consciente del riesgo. `GV.RR-02`: Roles y responsabilidades de riesgo establecidos. `GV.RR-03`: Asignación de recursos adecuados. `GV.RR-04`: Ciberseguridad en prácticas de RR.HH.	**Actividad 6, Actividad 7, Tarea 2 y Tarea 3**	En la **Tarea 2** se analizó la ética profesional frente a los mercados de exploits y la divulgación responsable. En las **Actividades 6 y 7** se asignó un **Propietario del Riesgo** (*Risk Owner*) y área responsable a cada escenario y acción del plan, además de justificar recursos e incluir políticas obligatorias para el personal.

Categoría	Subcategoría Relacionada	Actividad / Práctica / Tarea	Qué se hizo en el semestre y cómo se relaciona
GV.PO Políticas	`GV.PO-01`: Política para gestionar riesgos establecida y comunicada. `GV.PO-02`: Política revisada y actualizada para reflejar cambios en amenazas y tecnología (como IA).	**Clase, Actividad 1, Actividad 6 y Actividad 7**	En la **Actividad 1** se estudió el papel normativo de las políticas de Seguridad de la Información. En las **Actividades 6 y 7** se diseñó la actualización de políticas corporativas ante la adopción de herramientas de Inteligencia Artificial Generativa (*ShadowAI*).
GV.OV Supervisión (*Oversight*)	`GV.OV-01`: Revisión de resultados de la estrategia. `GV.OV-02`: Ajuste de estrategia ante incidentes. `GV.OV-03`: Evaluación del desempeño mediante métricas (KPIs y KRIs).	**Actividad 5, Actividad 6 y Actividad 7**	En la **Actividad 5** se analizaron incidentes recientes del sector para ajustar el registro de riesgos, y en la **Actividad 7** se diseñaron **3 Indicadores Clave de Riesgo (KRIs)** con métricas, frecuencias de medición y umbrales para evaluar el desempeño de los controles.
GV.SC Gestión de Riesgos en Cadena de Suministro	`GV.SC-01` a `GV.SC-05` y `GV.SC-07`: Estrategia, roles, priorización de proveedores críticos, requisitos contractuales y evaluación continua de riesgos de terceros.	**Actividad 2, Actividad 3, Actividad 5, Actividad 6 y Tarea 3**	En las **Actividades 2 y 3** se identificaron proveedores críticos de tecnología y nube; en la **Actividad 5** se estudiaron ataques reales a la cadena de suministro; en la **Actividad 6** se documentó el tratamiento del riesgo de proveedores mediante mitigación y transferencia contractual; y en la **Tarea 3** se analizó el riesgo de integraciones SaaS y proveedores MSP.

2.2. Función 2: IDENTIFY (ID) — Identificar

Tabla 3: Mapeo de Categorías y Subcategorías de la función **IDENTIFY (ID)** con las actividades del semestre.

Categoría	Subcategoría Relacionada	Actividad / Práctica / Tarea	Qué se hizo en el semestre y cómo se relaciona
ID.AM Gestión de Activos	`ID.AM-01`: Se mantienen inventarios de hardware gestionados por la organización.	**Práctica 3, Práctica 6, Práctica 7 y Actividad 3**	En la **Práctica 3** se realizó descubrimiento de hosts activos en la red local con `nmap -sP`, y en las **Prácticas 6 y 7** se creó un script de barrido para descubrir servidores ocultos en la red interna. En la **Actividad 3** se elaboró un inventario completo de hardware y endpoints.
	`ID.AM-02`: Se mantienen inventarios de software, servicios y sistemas.	**Práctica 2, Práctica 3, Práctica 6, Práctica 7 y Actividad 3**	En la **Práctica 2** se enumeraron subdominios con `subfinder` y tecnologías web con `httpx`; en la **Práctica 3** se identificaron puertos y versiones de servicios con `nmap -sV -A`; en las **Prácticas 6 y 7** se inventariaron procesos y sistemas operativos (`uname`, `ps`, `systeminfo`); y en la **Actividad 3** se realizó el catálogo de software, bases de datos y APIs.
	`ID.AM-03`: Se mantienen representaciones de la comunicación de red autorizada y flujos de datos internos y externos.	**Práctica 2, Práctica 6, Práctica 7 y Actividad 3**	En las **Prácticas 6 y 7** se inspeccionaron interfaces de red (`ifconfig -a`) y tablas de ruteo (`route -n`) para mapear la comunicación entre segmentos. En la **Actividad 3** se diseñó el diagrama de arquitectura y conectividad de red dividido en zonas de confianza y protocolos permitidos.
	`ID.AM-04`: Se mantienen inventarios de servicios proporcionados por proveedores.	**Práctica 2, Actividad 3 y Actividad 7**	En la **Práctica 2** se identificaron servicios externos en la nube (AWS y Cloudflare) asociados a dominios institucionales, y en las **Actividades 3 y 7** se inventariaron servicios Cloud, SaaS y APIs de terceros.
	`ID.AM-05`: Los activos se priorizan según su clasificación, criticidad e impacto en la misión.	**Actividad 3, Actividad 4 y Actividad 6**	En la **Actividad 3** se clasificaron y priorizaron los activos tecnológicos más críticos explicando el impacto operativo de su compromiso.

Categoría	Subcategoría Relacionada	Actividad / Práctica / Tarea	Qué se hizo en el semestre y cómo se relaciona
	`ID.AM-07`: Se mantienen inventarios de datos y metadatos para tipos de datos designados.	**Práctica 5, Práctica 6, Práctica 7, Actividad 3 y Actividad 7**	En las **Prácticas 5, 6 y 7** se realizó búsqueda y localización de archivos sensibles en el sistema (`find`, `grep -rnI`, respaldos y código fuente). En las **Actividades 3 y 7** se clasificaron los datos sensibles (propiedad intelectual, secretos criptográficos y datos personales).
	`ID.AM-08`: Los sistemas, hardware, software, servicios y datos se gestionan en su ciclo de vida (incluyendo detección de software obsoleto EOL y *Shadow IT / Shadow AI*).	**Práctica 1, Práctica 2, Práctica 4, Actividad 6 y Actividad 7**	En las **Prácticas 2 y 4** se identificaron sistemas y versiones fuera de soporte (EOL) como PHP 5.x y Debian 8.11 que aumentaban la superficie de ataque. En las **Actividades 6 y 7** se analizó a fondo el problema de **ShadowAI** (uso no autorizado de servicios de IA por empleados).
ID.RA Evaluación de Riesgos	`ID.RA-01`: Las vulnerabilidades en los activos se identifican, validan y registran.	**Práctica 2, Práctica 3, Práctica 4, Actividad 4 y Tarea 2**	En la **Práctica 2** se escaneó un servidor web con `nuclei` (detectando TLS 1.0/1.1 obsoletos y cifrados débiles); en la **Práctica 4** se ejecutó `LinPEAS` identificando y validando 13 CVEs de escalación de privilegios en Linux; y en la **Actividad 4** se investigaron y registraron 27 vulnerabilidades CVE con su debilidad CWE y severidad CVSS v3.1.
	`ID.RA-02`: Se recibe inteligencia de amenazas cibernéticas (CTI) de foros y fuentes. `ID.RA-03`: Las amenazas internas y externas se identifican y registran.	**Práctica 2, Actividad 1, Actividad 5, Presentación en Clase, Actividad 6, Actividad 7 y Tarea 3**	En la **Práctica 2** se integraron las APIs de inteligencia de VirusTotal y GitHub en `subfinder`. En la **Actividad 5** y en la **Presentación en clase** se investigaron los grupos de amenaza más activos y se diseñó una taxonomía de adversarios externos e internos. En la **Tarea 3** se revisaron las actualizaciones de **MITRE ATT&CK v21** y **MITRE ATLAS**.
	`ID.RA-04`: Se identifican y registran impactos potenciales y probabilidades. `ID.RA-05`: Amenazas, vulnerabilidades, probabilidades e impactos se usan para comprender el riesgo inherente y priorizar respuestas.	**Clase, Actividad 6 y Actividad 7**	En la **Actividad 6** se estructuraron 10 escenarios de riesgo en el Registro de Riesgos, y en la **Actividad 7** se estimó cuantitativamente la frecuencia anual y el impacto en cuatro dimensiones para calcular el nivel de riesgo inherente y priorizar su tratamiento.
	`ID.RA-06`: Las respuestas al riesgo se eligen, priorizan, planifican, rastrean y comunican (Registro de Riesgos y Plan de Acción POA&M). `ID.RA-07`: Gestión de cambios y excepciones.	**Actividad 6, Actividad 7 y Tarea 3**	En la **Actividad 6** se documentó el estado de los planes de acción en el Registro de Riesgos, y en la **Actividad 7** se construyó el **Plan de Acción e Hitos (POA&M)** con 5 controles técnicos, responsables y fechas compromiso.
	`ID.RA-08`: Se establecen procesos para recibir, analizar y responder a divulgaciones de vulnerabilidades.	**Tarea 2 y Actividad 4**	En la **Tarea 2** se investigó el ciclo de las vulnerabilidades *Zero-Day*, el funcionamiento de los mercados blanco, gris y negro, el rol de los *brokers* y la divulgación responsable (*Bug Bounty*).
ID.IM Mejora (*Improvement*)	`ID.IM-01`: Mejoras identificadas a partir de evaluaciones. `ID.IM-02`: Mejoras identificadas a partir de pruebas y ejercicios de seguridad (*Penetration Testing*). `ID.IM-03` y `ID.IM-04`: Mejora de procesos y planes de gestión de vulnerabilidades.	**Prácticas 2 a 7, Actividad 4, Actividad 7, Actividad 8 y Tarea 3**	A lo largo de las **Prácticas 2 a 7** se ejecutó una prueba de penetración (*Penetration Testing*) completa en laboratorio (reconocimiento, escaneo, acceso inicial, escalación de privilegios, cracking de hashes y movimiento lateral), identificando las mejoras requeridas. En la **Tarea 3** se estudió cómo validar coberturas de detección con pruebas reales (`T1055`).

2.3. Función 3: PROTECT (PR) — Proteger

Tabla 4: Mapeo de Categorías y Subcategorías de la función **PROTECT (PR)** con las actividades del semestre.

Categoría	**Subcategoría Relacionada**	**Actividad / Práctica / Tarea**	**Qué se hizo en el semestre y cómo se relaciona**
PR.AA Gestión de Identidad, Autenticación y Control de Acceso	`PR.AA-01`: Identidades y credenciales gestionadas para usuarios, servicios y hardware. `PR.AA-02`: Identidades vinculadas a credenciales individuales.	**Práctica 1, Práctica 2, Práctica 5, Práctica 6, Actividad 3 y Actividad 7**	En la **Práctica 1** se crearon cuentas de usuario individuales en Linux para no operar como `root`; en la **Práctica 2** se gestionaron llaves de API; en las **Prácticas 5 y 6** se auditaron los archivos `/etc/passwd`, `/etc/shadow` y credenciales en respaldos; y en las **Actividades 3 y 7** se definieron controles de gestión de identidades y rotación de secretos en bóvedas criptográficas.
	`PR.AA-03`: Usuarios, servicios y hardware son autenticados (políticas de fortaleza de contraseñas y MFA). `PR.AA-04`: Aserciones de identidad protegidas (SSO, OAuth 2.0).	**Práctica 3, Práctica 5, Práctica 7, Actividad 3, Actividad 6 y Actividad 7**	En la **Práctica 3** se auditó la debilidad de contraseñas en SSH mediante un ataque de diccionario con `Hydra`, y en la **Práctica 5** se auditaron hashes `SHA512-crypt` offline con `John the Ripper`, demostrando experimentalmente la importancia de aplicar políticas de complejidad de contraseñas y MFA.
	`PR.AA-05`: Permisos de acceso y autorizaciones definidos y aplicados bajo el principio de mínimo privilegio.	**Práctica 1, Práctica 4, Actividad 3 y Actividad 4**	En la **Práctica 1** se configuró el archivo `/etc/sudoers` para otorgar privilegios mínimos controlados. En la **Práctica 4** se auditaron con `LinPEAS` permisos excesivos en sockets y binarios SUID de root (`pkexec`), explotando `CVE-2021-4034` para demostrar el impacto de fallas en el control de privilegios.
PR.AT Concientización y Capacitación	`PR.AT-01`: Concientización y capacitación general al personal. `PR.AT-02`: Capacitación especializada según el rol.	**Actividad 6 y Actividad 7**	En las **Actividades 6 y 7** se incluyeron programas de capacitación y evaluación obligatoria para el personal sobre ingeniería social, manejo seguro de código fuente y políticas de uso aceptable de IA.
PR.DS Seguridad de los Datos	`PR.DS-01`: Se protege la confidencialidad, integridad y disponibilidad de los datos en reposo (*data-at-rest*).	**Práctica 5, Práctica 6, Práctica 7, Actividad 1 y Actividad 3**	En la **Práctica 5** se verificó la integridad de archivos en reposo con `sha256sum` y se analizó el cifrado/hashing de contraseñas en `/etc/shadow`. En la **Práctica 6** se evidenció el riesgo de dejar contraseñas en texto plano en respaldos. En la **Práctica 7** se calculó el hash `SHA256` del código fuente en Windows con `certutil -hashfile`.
	`PR.DS-02`: Se protege la confidencialidad, integridad y disponibilidad de los datos en tránsito (*data-in-transit*).	**Práctica 2, Práctica 5, Práctica 7, Actividad 3 y Actividad 7**	En la **Práctica 2** se auditaron protocolos TLS y suites de cifrado en tránsito con `nuclei`; en la **Práctica 5** se realizaron transferencias cifradas con `scp` validando hashes en ambos extremos; en la **Práctica 7** se creó un túnel cifrado SSH (`ssh -L`) para encapsular tráfico RDP; y en la **Actividad 7** se definieron controles DLP y CASB para bloquear fugas de datos hacia Internet.
	`PR.DS-10`: Protección de datos en uso (*data-in-use*). `PR.DS-11`: Copias de seguridad (respaldos) creadas, protegidas y probadas.	**Práctica 6, Actividad 3, Actividad 6, Actividad 7 y Tarea 3**	En la **Práctica 6** se inspeccionaron respaldos comprimidos (`tar -ztvf`) comprobando las consecuencias de no cifrar ni aislar las copias de seguridad. En la **Tarea 3** se analizó la inyección en memoria (`T1055`) y cómo el ransomware elimina respaldos antes de cifrar un sistema.

Categoría	Subcategoría Relacionada	Actividad / Práctica / Tarea	Qué se hizo en el semestre y cómo se relaciona
PR.PS Seguridad de Plataformas	`PR.PS-01`: Prácticas de gestión de configuración. `PR.PS-02`: Mantenimiento y actualización de software (reemplazo de software EOL). `PR.PS-04`: Generación de registros de log. `PR.PS-05`: Prevención de software no autorizado. `PR.PS-06`: Desarrollo seguro de software (SDLC).	**Práctica 1, Práctica 2, Práctica 4, Práctica 6, Práctica 7, Actividad 4, Actividad 7 y Tarea 3**	En la **Práctica 1** se configuraron repositorios oficiales (`sources.list`) y se aplicaron actualizaciones con `apt update && apt upgrade`. En las **Prácticas 2, 4, 6 y 7** se auditaron configuraciones inseguras, software EOL, falta de integridad SRI en scripts web y credenciales expuestas en respaldos de código. En la **Tarea 3** se estudió la generación de logs con PowerShell (Eventos 4103/4104) y Sysmon (Eventos 1, 7 y 17).
PR.IR Resiliencia de la Infraestructura Tecnológica	`PR.IR-01`: Redes y entornos protegidos y segmentados lógicamente. `PR.IR-03` y `PR.IR-04`: Mecanismos de resiliencia, alta disponibilidad y capacidad ante DDoS.	**Práctica 2, Práctica 6, Práctica 7, Actividad 3 y Actividad 6**	En las **Prácticas 6 y 7** se comprobó prácticamente el aislamiento entre dos segmentos de red distintos y cómo un equipo con doble interfaz de red permite realizar pivoteo si no se restringe el reenvío de puertos. En la **Práctica 2** se verificó el uso de Cloudflare WAF/CDN, y en la **Actividad 3** se diseñó la segmentación de red en 4 zonas.

2.4. Función 4: DETECT (DE) — Detectar

Tabla 5: Mapeo de Categorías y Subcategorías de la función **DETECT (DE)** con las actividades del semestre.

Categoría	Subcategoría Relacionada	Actividad / Práctica / Tarea	Qué se hizo en el semestre y cómo se relaciona
DE.CM Monitoreo Continuo	`DE.CM-01`: Las redes y los servicios de red se monitorean para encontrar eventos potencialmente adversos.	**Práctica 2, Práctica 6, Práctica 7, Actividad 3 y Actividad 7**	En las **Prácticas 2, 6 y 7** se verificaron servicios de red, registros DNS y puertos activos, mientras que en las **Actividades 3 y 7** se definió el monitoreo continuo de tráfico de red y consultas DNS/HTTPS hacia dominios no autorizados (KRI 1).
	`DE.CM-03`: La actividad del personal y el uso de tecnología se monitorean (incluyendo el monitoreo continuo de **tecnología de ciberengaño / Deception y Honeypots**).	**Tarea 1 y Actividad 7**	En la **Tarea 1** se estudió a fondo el uso de **Deception y Honeypots** en ciberseguridad defensiva: despliegue y monitoreo continuo de *Honey files* (archivos trampa), *Honey tokens* (llaves API y credenciales falsas) y cuentas señuelo en Active Directory para detectar intrusos y ataques de *Kerberoasting*. En la **Actividad 7** se definió el monitoreo de uso de herramientas no autorizadas mediante DLP/CASB.
	`DE.CM-06`: Las actividades y servicios de proveedores externos se monitorean. `DE.CM-09`: El hardware, software, entornos de ejecución (*runtime*) y datos se monitorean.	**Práctica 6, Actividad 3, Actividad 7 y Tarea 3**	En la **Práctica 6** se inspeccionaron los procesos en ejecución (`ps aux awf`) en el servidor. En la **Tarea 3** se analizó el monitoreo de actividad en proveedores SaaS/MSP, la detección de inyección de procesos en tiempo de ejecución y la detección de evasión de defensas (AMSI/ETW/BYOVD) con EDR y Sysmon.
DE.AE Análisis de Eventos Adversos	`DE.AE-02`: Análisis de eventos potencialmente adversos (SIEM). `DE.AE-03`: Correlación de información de múltiples fuentes. `DE.AE-04`: Estimación de impacto y alcance.	**Tarea 1, Tarea 3, Actividad 3 y Actividad 7**	En la **Tarea 3** (conferencias *Obfuscated Tale* y *Multi-Tenant Kill Chain Correlation*) se estudió la diferencia entre recolectar logs y analizarlos en un **SIEM**, así como la correlación de eventos entre múltiples fuentes (identidad, endpoints y nube). En la **Actividad 7** se diseñó la correlación de alertas de firewall, DLP y repositorios.

Categoría	Subcategoría Relacionada	Actividad / Práctica / Tarea	Qué se hizo en el semestre y cómo se relaciona
	`DE.AE-06`: Entrega de alertas al SOC y sistemas de tickets. `DE.AE-07`: Integración de ciberinteligencia (CTI) en el análisis. `DE.AE-08`: Declaración de incidentes y reducción de falsos positivos.	**Tarea 1, Tarea 3, Actividad 5 y Actividad 7**	En la **Tarea 1** se analizó el problema del exceso de ruido y **falsos positivos en el SOC**, y cómo el envío de alertas desde señuelos (*Honeypots*) vía `syslog` o *webhooks* permite declarar incidentes con alta certeza. En la **Tarea 3** se estudió cómo distinguir entre una anomalía y una evidencia real de compromiso.

2.5. Función 5: RESPOND (RS) — Responder

Tabla 6: Mapeo de Categorías y Subcategorías de la función **RESPOND (RS)** con las actividades del semestre.

Categoría	Subcategoría Relacionada	Actividad / Práctica / Tarea	Qué se hizo en el semestre y cómo se relaciona
RS.MA Gestión de Incidentes	`RS.MA-01`: Ejecución del plan de respuesta a incidentes. `RS.MA-02`: Triaje y validación de reportes de incidentes. `RS.MA-03`: Categorización y priorización de incidentes (incluyendo el balance entre contener rápido u observar al atacante en un Honeypot).	**Tarea 1, Tarea 2, Tarea 3, Actividad 5, Actividad 6 y Actividad 7**	En la **Tarea 1** se estudió la estrategia de mantener al atacante interactuando dentro de un **Honeypot** controlado para observar sus técnicas antes de contenerlo. En las **Actividades 5, 6 y 7** se categorizaron los incidentes por tipo (ransomware, DDoS, fuga de datos, compromiso de cuenta) y se estimaron los costos y tiempos de respuesta del SOC.
RS.AN Análisis de Incidentes	`RS.AN-03`: Análisis para determinar qué ocurrió durante un incidente, su causa raíz y revisión de tecnología de ciberengaño (*Deception*).	**Tarea 1, Tarea 2 y Actividad 5**	En la **Tarea 2** y en la **Actividad 5** se realizó el análisis de causa raíz, vector de entrada y cadena de ataque de incidentes históricos reales (*Operation Triangulation*, *MOVEit*, *EternalBlue*/*WannaCry* y 5 ciberataques en la industria automotriz). En la **Tarea 1** se estudió el análisis forense de las acciones del intruso registradas en un Honeypot.
	`RS.AN-07`: Recolección de datos y metadatos del incidente preservando su integridad y procedencia. `RS.AN-08`: Estimación y validación de la magnitud del incidente.	**Práctica 4, Práctica 5, Práctica 6 y Práctica 7**	En la **Práctica 5**, al extraer los archivos de contraseñas del servidor, se calculó su hash criptográfico con `sha256sum` antes y después de la transferencia para preservar y comprobar la integridad de la evidencia recolectada. En la **Práctica 7** se verificó el hash `SHA256` del código recolectado con `certutil`, y en las **Prácticas 4 y 6** se dimensionó el alcance del compromiso en el servidor y la red interna.
RS.CO Reporte y Comunicación de Respuesta	`RS.CO-02`: Notificación de incidentes a partes interesadas internas y externas. `RS.CO-03`: Intercambio de información con áreas designadas.	**Actividad 5, Actividad 6 y Actividad 7**	En las **Actividades 5 y 7** se analizaron las obligaciones de notificación de brechas de datos a clientes afectados, socios comerciales, autoridades regulatorias y dirección.
RS.MI Mitigación de Incidentes	`RS.MI-01`: Contención de incidentes. `RS.MI-02`: Erradicación de incidentes.	**Práctica 4, Actividad 6 y Actividad 7**	En la **Práctica 4** se realizó la limpieza y eliminación de los binarios compilados (`make clean`) tras la prueba de escalación de privilegios. En las **Actividades 6 y 7** se definieron las acciones de contención en firewall/EDR y erradicación mediante revocación y rotación inmediata de credenciales y llaves criptográficas comprometidas.

2.6. Función 6: RECOVER (RC) — Recuperar

Tabla 7: Mapeo de Categorías y Subcategorías de la función **RECOVER (RC)** con las actividades del semestre.

Categoría	Subcategoría Relacionada	Actividad / Práctica / Tarea	Qué se hizo en el semestre y cómo se relaciona
RC.RP Ejecución del Plan de Recuperación	`RC.RP-01` y `RC.RP-02`: Ejecución del plan de recuperación y selección/priorización de acciones de restauración. `RC.RP-04` y `RC.RP-05`: Consideración de funciones críticas de misión y verificación de servicios restaurados.	**Actividad 3, Actividad 5, Actividad 6 y Tarea 2**	En la **Tarea 2** (*WannaCry*) y en la **Actividad 5** se analizó el impacto y proceso de recuperación operativa tras ataques de ransomware que detuvieron operaciones críticas, y en las **Actividades 3 y 6** se priorizó el orden de restauración de los sistemas según su criticidad.
	`RC.RP-03`: La integridad de las copias de seguridad (respaldos) y otros activos de restauración se verifica antes de usarlos.	**Práctica 5, Práctica 6, Práctica 7 y Tarea 3**	En la **Práctica 6** se inspeccionaron archivos de respaldo comprimidos (`tar -ztvf`) en el servidor Linux, y en las **Prácticas 5 y 7** se aplicó la verificación de integridad criptográfica mediante hashes **SHA-256** (`sha256sum` y `certutil -hashfile`) para comprobar que los archivos no hubieran sido alterados ni corrompidos.
RC.CO Comunicación de Recuperación	`RC.CO-03`: Comunicación de las actividades y progreso de recuperación a partes interesadas internas y externas.	**Actividad 5 y Actividad 7**	Se revisó la comunicación hacia clientes, socios y alta dirección durante y después de la restauración de servicios afectados por un incidente.

3. Total de Categorías y Subcategorías Cubiertas en el Curso

Como resultado final de la revisión y mapeo de **The NIST Cybersecurity Framework (CSF) 2.0** frente a los temas vistos en clase, las Actividades 1 a 7, las Prácticas 1 a 7, la Presentación en clase y las Tareas 1 a 3, se obtuvo la siguiente cobertura:

- **Categorías cubiertas en el curso:** Se encontraron **22 de las 22 categorías (100 %)** del framework relacionadas con al menos una actividad, práctica, tarea o tema visto durante el semestre.
- **Subcategorías cubiertas en el curso:** Se encontraron **89 de las 106 subcategorías (84.0 %)** del framework cubiertas a lo largo del semestre.

Tabla 8: Conteo final de Categorías y Subcategorías del NIST CSF 2.0 cubiertas en el curso.

Función Core del Framework	Categorías Cubiertas	Subcategorías Cubiertas	Porcentaje de Subcategorías
1. GOVERN (`GV`)	**6 de 6** (100 %)	**25 de 31**	80.6 %
2. IDENTIFY (`ID`)	**3 de 3** (100 %)	**19 de 21**	90.5 %
3. PROTECT (`PR`)	**5 de 5** (100 %)	**19 de 22**	86.4 %
4. DETECT (`DE`)	**2 de 2** (100 %)	**10 de 11**	90.9 %
5. RESPOND (`RS`)	**4 de 4** (100 %)	**10 de 13**	76.9 %
6. RECOVER (`RC`)	**2 de 2** (100 %)	**6 de 8**	75.0 %
TOTAL EN EL CURSO	**22 de 22 (100 %)**	**89 de 106**	**84.0 %**

Referencias Bibliográficas

National Institute of Standards and Technology. (2024, febrero). *The NIST Cybersecurity Framework (CSF) 2.0 (NIST CSWP 29)* (inf. téc.). U.S. Department of Commerce, National Institute of Standards y Technology. https://doi.org/10.6028/NIST.CSWP.29